

DPDP COMPLIANCE AUDIT

finance-data-processing

Digital Personal Data Protection Act 2023



Grade A — Strong

Scanned: 08 April 2026

Files indexed: 14

Languages: express, pg, jsonwebtoken, bcryptjs, express-validator, cors

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

The application collects user name, email, and password for authentication and user management, and financial record details for analysis. The primary DPDP risk lies in the potential for unauthorized access to user credentials and financial data due to insufficient granular access controls or data breach.

Total findings: 13

HIGH: 1

MEDIUM: 2

INFO: 4

PASS: 4

Tech Stack: express, pg, jsonwebtoken, bcryptjs, express-validator

Risk Profile: The application collects user name, email, and password for authentication and user management, and financial record details for analysis. The primary DPDP risk lies in the potential for unauthorized access to user credentials and financial data due to insufficient granular access controls or data breach.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	18/18 (100%)	PASS
Section 8	10	7.0/10 (70%)	WARN
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	4.0/8 (50%)	WARN
Section 8(6)	8	6.8/8 (85%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal		0/4 (0%)	FAIL

Estimated Total Remediation Effort: 1.1–4.2 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Application Logs

PII fields: password, email, address

users.js → userController.js → database.js

Flow 2: Application Logs

PII fields: password, email

auth.js → authController.js → database.js

Rule	Section	Severity	File
GRIEVANCE_OFFICER_MISSING	Section 13 — Grievance Redressal	HIGH	N/A
AUDIT_TRAIL_PARTIAL	Section 8(4) — Audit Trail	MEDIUM	N/A
INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
NO_BREACH_ALERTING	Section 8(6) — Breach	LOW	N/A
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	src/routes/users.js
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
CONSENT_PRESENT	Section 6 — Consent	PASS	src/routes/auth.js
CONSENT_WITHDRAWAL_PRESENT	Section 6(6) — Consent Withdrawal	PASS	src/controllers/auth Controller.js
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	src/routes/records.js
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	src/routes/auth.js

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (1–4 hours)

Fix immediately — these represent the highest legal exposure.

- Grievance Officer Missing (1–4 hrs)

Week 2 — High Priority (4–16 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Audit Trail Partial (2–8 hrs)
- Incomplete Deletion Coverage (2–8 hrs)

Week 4 — Advisory (4–14 hours)

Address before next compliance review.

- No Breach Alerting (2–6 hrs)
- Data Portability Missing (2–8 hrs)

Total estimated remediation effort: 9–34 hours (1.1–4.2 engineering days)

Changes Since 2026-04-08

— 13 finding(s) unchanged

Details

Finding 1 of 13

[Section 13 — Grievance Redressal]

1. [HIGH] GRIEVANCE_OFFICER_MISSING — N / A

Estimated fix time: 1–4 hours

No compliant Grievance Officer / DPO publication found. A PASS requires grievance-related text or a dedicated route **and** a contact email or dedicated grievance/DPO URL. Tiny repos without a grievance route are not marked PASS.

Risk:

Failure to designate a Grievance Officer means individuals have no clear channel to raise concerns about their data, potentially leading to unresolved disputes and non-compliance with DPDP requirements.

Fix:

1. Create a new route (e.g., `/api/grievance`) that displays contact information for the designated Grievance Officer.
2. Add a dedicated email address or a contact form to this route for submitting grievances.
3. Ensure this route is publicly accessible or clearly linked from your privacy policy.
4. Update your privacy policy to reference the designated Grievance Officer and their contact details.

DPDP:

Section 13(1) — Requires the appointment of a Grievance Officer to address data principal complaints.

Example:

```
const express = require('express'); const router = express.Router(); router.get('/grievance',  
(req, res) => { res.json({ message: 'Grievance Officer Contact Information', name: 'Jane Doe',  
email: 'grievance.officer@example.com', phone: '+1234567890' }); }); module.exports = router;
```

Finding 2 of 13

[Section 8(4) — Audit Trail]

2. [MEDIUM] AUDIT_TRAIL_PARTIAL — N / A**Estimated fix time:** 2–8 hours

Partial audit trail detected. Found: change tracking. Missing: access logging, audit model.

Risk:

The absence of a complete audit trail hinders the ability to track data access and modifications, making it difficult to investigate potential breaches or unauthorized activities and demonstrate compliance.

Fix:

1. Implement middleware to log all API requests, including user ID, timestamp, endpoint accessed, and HTTP method.
2. Create a dedicated 'AuditLog' model to store these access events.
3. Ensure that all data modification operations (create, update, delete) are logged with before/after states.
4. Add a new API endpoint to retrieve audit logs, with appropriate access controls.

DPDP:

Section 8(4) — Mandates the maintenance of an audit trail for all processing activities involving personal data.

Example:

```
const auditLog = require('../models/AuditLog'); // Assuming you create this model // Example
middleware for logging access app.use(async (req, res, next) => { await auditLog.create({
  userId: req.user.id, // Assuming user is authenticated endpoint: req.originalUrl, method:
  req.method, timestamp: new Date() }); next(); });
```

Finding 3 of 13

[Section 8 — Data Principal Rights]

3. [MEDIUM] INCOMPLETE_DELETION_COVERAGE — N / A**Estimated fix time:** 2–8 hours

Deletion mechanism detected but may not cover all PII storage. Uncovered files: src/config/database.js. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Risk:

Incomplete data deletion means personal data may persist beyond authorized retention periods or after a deletion request, violating data principal rights and DPDP requirements for erasure.

Fix:

1. Identify all locations where PII is stored (databases, file systems, caches, third-party services).
2. Implement a centralized data deletion service that can be called to remove PII from all identified storage locations.
3. Ensure the `deleteUser` controller function (or equivalent) calls this centralized service.
4. Add comprehensive unit and integration tests to verify complete data erasure across all systems.

DPDP:

Section 8(1) — Stipulates that data controllers must erase personal data when it is no longer necessary for the purpose for which it was collected.

Example:

```
async function deleteUserData(userId) { // Example: Delete from primary database await
User.findByIdAndDelete(userId); // Example: Delete from a separate analytics store await
AnalyticsData.deleteMany({ userId: userId }); // Example: Clear from cache await
cache.del(`user:${userId}`); console.log(`User data for ${userId} deleted from all systems.`);
}
```

Finding 4 of 13

[Section 8(6) — Breach]

4. [LOW] NO_BREACH_ALERTING — N / A**Estimated fix time:** 2–6 hours

Structured logging detected but no breach notification mechanism found. DPDP Section 8(6) requires notifying affected individuals and the Authority without undue delay when a breach occurs. Logging alone is insufficient — implement automated alerting (Sentry, PagerDuty, or equivalent) with escalation to a compliance team.

Risk:

The lack of a data breach alerting system means the organization cannot promptly notify affected individuals or the relevant authorities as required by DPDP, increasing potential harm and regulatory penalties.

Fix:

1. Integrate a security monitoring tool or service that can detect potential data breaches or suspicious activities.
2. Develop a notification system (e.g., email, SMS) to alert administrators and potentially affected users upon detection of a breach.
3. Define clear protocols for responding to alerts, including investigation and remediation steps.
4. Ensure the alerting system is configured to meet the DPDP's timelines for notification.

DPDP:

Section 4(1) — Requires data fiduciaries to implement reasonable security safeguards to prevent data breaches.

Example:

```
const breachNotifier = require('../services/breachNotifier'); // Your notification service //
Example: Triggered by a security monitoring system or anomaly detection function
handlePotentialBreach(breachDetails) { console.error('Potential data breach detected:',
breachDetails); breachNotifier.notifyAdmins(breachDetails); // Logic to determine if user
notification is required based on severity if (breachDetails.requiresUserNotification) {
breachNotifier.notifyUsers(breachDetails.affectedUsers); } }
```

Finding 5 of 13

[Section 11 — Data Portability]

5. [LOW] DATA_PORTABILITY_MISSING — N / A**Estimated fix time:** 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

The absence of a data portability feature means users cannot exercise their right to obtain their personal data in a usable format, which is a direct violation of DPDP Section 11. This can lead to user dissatisfaction and potential regulatory penalties.

Fix:

1. Create a new Express route (e.g., '/api/data-export') that handles GET requests.
2. Implement middleware to authenticate and authorize the user requesting their data.
3. In the controller, fetch the authenticated user's personal data from the database.
4. Format the data as a JSON array or CSV and set appropriate response headers (e.g., 'Content-Disposition', 'Content-Type') for download.

DPDP:

Section 11(1) — Data Fiduciaries shall provide Data Principals with their personal data in a structured, commonly used and machine-readable format.

Example:

```
router.get('/data-export', authenticate, (req, res) => { // Fetch user data based on
req.user.id const userData = getUserData(req.user.id); res.setHeader('Content-Type',
'application/json'); res.setHeader('Content-Disposition', 'attachment;
filename="my_data.json"); res.status(200).json(userData); });
```

Finding 6 of 13

[Section 7 — Legitimate Use]

6. [INFO] INTERNAL_ROUTE_PII_ACCESS — src / routes / users.js

Internal file (users.js) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 7 of 13

[Section 5 — Notice]

7. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 8 of 13

[Section 5 — Purpose Limitation]

8. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 9 of 13

[Section 16 — Cross-Border Transfer]

9. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 10 of 13

[Section 6 — Consent]

10. [PASS] CONSENT_PRESENT — src / routes / auth.js

Framework auth/consent middleware detected in this file.

Finding 11 of 13

[Section 6(6) — Consent Withdrawal]

11. [PASS] CONSENT_WITHDRAWAL_PRESENT — src / controllers / authController.js

Consent withdrawal mechanism detected. Found in: src/controllers/authController.js (line 74)

Finding 12 of 13

[Section 8 — Data Principal Rights]

12. [PASS] DELETION_MECHANISM_PRESENT — src / routes / records.js

Data deletion mechanism detected. Found 2 deletion endpoint(s) and 7 deletion signal(s). Note: Verify deletion cascades to all PII tables (sessions, logs, related records).

Fix:

1. Verify deletion cascades to: sessions, audit_logs, third-party sync records.
2. Use database CASCADE DELETE or explicit multi-table deletion in deletion service.
3. Test deletion completeness: create account, delete, query all PII tables for orphaned data.

Finding 13 of 13

[Section 11 — Right to Access]

13. [PASS] DATA_ACCESS_PRESENT — src / routes / auth.js

Data access endpoint detected for authenticated users.

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] No age verification for user registration

Confidence: 60%

Section 9 — Children's Data

The `POST /api/auth/register` data flow and `src/controllers/authController.js` do not show any mechanism for verifying user age before account creation, which is a requirement for handling children's data under DPDP.

Recommendation: Implement an age verification step during user registration. This could involve asking for date of birth and checking if the user is below the age of consent, or implementing a parental consent flow if applicable.

[AI-INFERRED] Incomplete audit trail for data access

Confidence: 55%

Section 8(4) — Audit Trail

The `AUDIT\_TRAIL\_PARTIAL` rule fired, and the `data\_flows` indicate various endpoints like `GET /api/users/{id}`, `GET /api/records/{id}`, and dashboard endpoints retrieve user and financial data. However, there's no explicit mention or code evidence of logging *who* accessed *what* personal data and *when* for all these read operations.

Recommendation: Enhance the logging mechanism to capture all read access to personal data. For each GET request that retrieves PII (e.g., user details, financial records), log the authenticated user's ID, the timestamp, and the specific data accessed.

[AI-INFERRED] Potential PII use in admin views

Confidence: 30%

Section 5 — Purpose Limitation

The `data\_flows` show `GET /api/users/{id}` retrieves user details including name and email. While this is for user management, the `risk\_surface\_summary` mentions 'admin views'. It's unclear if these user details are exposed in any administrative interfaces without a specific, documented purpose beyond general user management.

Recommendation: Review all endpoints that retrieve user PII (name, email) and ensure they are strictly necessary for the intended purpose. If these are used in administrative dashboards or views, confirm that the purpose is clearly defined and documented, and that access is restricted to authorized personnel.